LECTURE 5

Unsupervised Learning Part 2: Anomaly Detection and Cybersecurity

Reference Text

Statistical outlier tests, Mahalanobis distance, Isolation Forest, one-class SVM, autoencoders and graph methods — for intrusion and insider-threat detection

AK DHAMIJA, Researcher & Instructor, AI & Machine Learning

dhamija.ak@gmail.com • 9811453163

Unit 4: Simulation Strategies in Warfare — AI & Machine Learning in Warfare

This reference text expands every slide of the lecture into full explanations, derivations, worked examples and figures. Read it alongside the slides; work the "check your understanding" boxes before looking at the answers.

Contents

1 What Anomaly Detection Is **3**

2 Statistical Methods **3**

2.1 z-scores and IQR fences . . . 3

2.2 Mahalanobis distance . . . 3

3 Isolation Forest **4**

3.1 Idea . . . 4

4 One-Class SVM **4**

5 Autoencoders **5**

5.1 Reconstruction error . . . 5

5.2 The three-tier architecture . . . 5

6 Insider Threat: Behaviour Baselines **5**

7 Graph-Based Detection **6**

8 Comparison **6**

9 Deeper Dive I: Evaluating Detectors Properly **6**

9.1 Choosing the operating point . . . 6

9.2 Partial AUC and precision at k . . . 7

10 Deeper Dive VI: Building an ROC Curve from Scores **7**

11 Deeper Dive II: Statistical Detectors in Detail **7**

11.1 Robust location and scale . . . 7

11.2 From Mahalanobis distance to a threshold . . . 8

12 Deeper Dive III: Isolation Forest Mechanics **8**

13 Deeper Dive IV: Autoencoder Design **8**

13.1 Architecture choices . . . 8

13.2 Per-feature errors for explanation . . . 8

13.3 Concept drift . . . 9

14 Deeper Dive V: Adversaries Who Know the Detector **9**

Part C — Further Theory, Methods and Applications **10**

15 Anomalies as Low-Probability Events **10**

15.1 The density view . . . 10
15.2 From Mahalanobis distance to a principled threshold . . . 10
15.3 Extreme value theory . . . 10

16 Local Outlier Factor and Neighbour-Based Scores 10

17 Isolation Forest: the Score Function 11

18 Boundary Methods: One-Class SVM and SVDD 11

19 Detecting Change in Sensor and Platform Data 12
19.1 Three control charts . . . 12
19.2 Predictive maintenance . . . 12

20 Network Intrusion Detection: Domain Knowledge 13
20.1 What the detector sees . . . 13
20.2 Signature and anomaly detection . . . 13
20.3 The attack life cycle . . . 13
20.4 The base-rate fallacy for intrusion detection . . . 13

21 Insider Threat and Behaviour Analytics 13

22 Graph Signals: Rarity and Lateral Movement 14

23 Operating Detectors in Practice 14
23.1 Evaluation over time . . . 14
23.2 Alert triage and the feedback loop . . . 14
23.3 Adversaries who learn . . . 14

24 Further Self-Test Questions 15

25 Implementation Notes 15

26 Self-Test Questions 15

27 Across the Disciplines 16

28 Glossary 16

1 What Anomaly Detection Is

Definition — anomaly detection

Learning a model of *normal* behaviour from (mostly) normal data and flagging observations that deviate from it. Because no examples of attacks are required, anomaly detection can catch **zero-day** threats that have never been seen before — the decisive advantage over supervised classifiers, which only recognise classes present in training.

Three types: **point** anomalies (a single unusual record, e.g. a 3 a.m. login from a foreign address); **contextual** anomalies (normal in one context, abnormal in another, e.g. a large transfer at midnight on a weekday rather than on backup day); **collective** anomalies (each record normal, the group abnormal, e.g. 1,000 connection attempts in 10 ms — a port scan).

Case A: 500,000 network packet records from a 24-hour log, 3.6% attacks (DoS, probe, remote-to-local, user-to-root), 41 features. **Case B**: 500 users × 1,000 activity logs with 15 compromised accounts (0.003%), 18 behaviour features (login hour and location, files accessed, e-mail recipients, USB events, data volume, privilege-escalation attempts, . . .).

Pitfall — accuracy under extreme imbalance

In Case B a detector that never raises an alarm is 99.997% accurate. Evaluate with true-positive rate (recall), false-positive rate, precision at the operational base rate, and AUROC — never accuracy.

2 Statistical Methods

2.1 z-scores and IQR fences

The z-score $z = (x - \mu)/\sigma$ flags values beyond $|z| > 3$ (or 2.5). For source bytes, normal traffic has $\mu = 4{,}218$, $\sigma = 2{,}104$: user-to-root attacks (mean 11,240 bytes, $z = +3.34$) are flagged, but DoS packets (1.2 bytes, $z = -2.0$) are not. The interquartile-range rule flags $x < Q_1 - 1.5\,\mathrm{IQR}$ or $x > Q_3 + 1.5\,\mathrm{IQR}$, which is robust to the outliers themselves. Here $Q_1 = 2{,}840$, $Q_3 = 5{,}620$, IQR $= 2{,}780$, giving fences at $-1{,}330$ and 9,790.

Pitfall — check the arithmetic

The lower fence is negative, so DoS traffic at 1.2 bytes lies inside it and is *not* flagged, contrary to a claim in the original lecture material. More fundamentally, univariate rules examine one feature at a time and miss attacks that are unusual only in combination.

2.2 Mahalanobis distance

$$D_M(x) = \sqrt{(x - \mu)^\top \Sigma^{-1} (x - \mu)}.$$

Multiplying by Σ^{-1} rescales each direction by its variance and removes correlations, so the "normal region" is an ellipse aligned with the data rather than a circle. A point can lie within normal ranges on every feature yet be far outside the ellipse because it breaks a correlation. Under multivariate normality $D_M^2 \sim \chi^2_d$, which supplies thresholds. Mean D_M was 4.12 for normal traffic, 7.24 for probes, 9.83 for R2L, 12.41 for DoS and 18.72 for U2R; with threshold 9.46, TPR was 72.1% at FPR 1.8%.

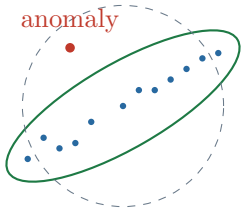


Figure 1: the anomaly is inside the Euclidean circle (dashed) but outside the Mahalanobis ellipse.

Pitfall — contaminated covariance

If anomalies are included when estimating μ and Σ, they inflate the covariance and hide themselves ("masking"). Use a robust estimator such as the minimum covariance determinant, computed from the most central half of the data.

3 Isolation Forest

3.1 Idea

Anomalies are few and different, so they are easier to *isolate*. Build random trees by repeatedly choosing a random feature and a random split value within its range. A typical normal point, surrounded by others, needs many splits before it sits alone in a leaf; an anomaly is separated after very few.

Definition — Isolation Forest anomaly score

$$s(x,\psi) = 2^{-E[h(x)]/c(\psi)}, \qquad c(\psi) = 2H(\psi-1) - \frac{2(\psi-1)}{\psi}, \quad H(i) \approx \ln i + 0.5772,$$

where $h(x)$ is the path length to isolate x, averaged over the trees, and $c(\psi)$ the average path length in a random tree built on ψ points (a normaliser). $s \to 1$: anomaly; $s \le 0.5$: normal.

Each tree uses a sub-sample of $\psi = 256$ points: small samples keep normal points crowded and anomalies isolated, amplifying the contrast. With 100 trees, training is $O(B\psi \log \psi)$ (0.4 s on Case A) and scoring a packet takes about 800 comparisons (0.002 ms) — fast enough to screen every packet in real time. Average path lengths were 6.7–7.1 for normal services and 2.0–3.4 for attacks; Case A: TPR 91.4%, FPR 1.1%, AUROC 0.976.

Defence & wargaming application — zero-day SIGINT detection

Against a 90-day baseline of emitter parameters, a never-seen low-probability-of-intercept radar scored 0.91 while routine and civilian emitters scored about 0.4. No label was needed. "Unusual" is not "hostile": every alert needs analyst confirmation before the threat library is updated.

4 One-Class SVM

The one-class SVM (Schölkopf et al., 2001) separates the training data from the origin in a kernel feature space with maximum margin:

$$\min \tfrac{1}{2}\|w\|^2 + \frac{1}{\nu N}\sum_i \xi_i - \rho \quad \text{s.t. } w\cdot\phi(x_i) \ge \rho - \xi_i, \qquad f(x) = \operatorname{sign}\Big(\sum_i \alpha_i K(x_i,x) - \rho\Big).$$

In input space the RBF kernel yields a tight, flexible boundary around normal data. The parameter $\nu \in (0,1]$ is an upper bound on the fraction of training points treated as outliers and a lower bound

on the fraction of support vectors; set it near the target false-positive rate. Best grid point $\nu = 0.05$, $\gamma = 0.10$: TPR 89.7%, FPR 0.9%. Training is $O(N^2)$ or worse — 38.4 s even after restricting to normal data — so large datasets must be sub-sampled (50,000 points gave 88.9%).

5 Autoencoders

5.1 Reconstruction error

An autoencoder compresses an input through a narrow bottleneck and reconstructs it: $h = f_{\text{enc}}(x)$, $\hat{x} = f_{\text{dec}}(h)$, trained to minimise $\frac{1}{N}\sum \|x_i - \hat{x}_i\|^2$ *on normal data only.* It learns to rebuild normal traffic well and anything else poorly, so the reconstruction error

$$\text{RE}(x) = \|x - \hat{x}\|^2$$

is an anomaly score. Case A used $41 \to 32 \to 16 \to 32 \to 41$ units; normal RE averaged 0.024 (s.d. 0.018) while attack types averaged 0.29–0.46. The threshold $\tau = 0.087$ was chosen on validation data to give a 0.6% false-positive rate — the false-alarm budget is fixed first and the detection rate follows. Result: **TPR 95.8%, FPR 0.6%, AUROC 0.988**, the best of all methods; by attack type 97.2% (DoS), 94.1% (probe), 92.8% (R2L, which imitates legitimate logins) and 98.4% (U2R).

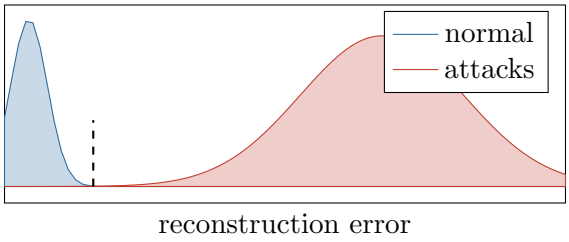


Figure 2: reconstruction-error distributions and the threshold (schematic shapes).

Variants: variational autoencoders (probabilistic latent space, likelihood scores); sparse autoencoders; convolutional and LSTM autoencoders for sequences.

5.2 The three-tier architecture

Tier 1: Isolation Forest screens every packet in microseconds. Tier 2: the autoencoder (or OCSVM) examines only flagged packets. Tier 3: analysts review high-confidence alerts and feed new signatures back into the baseline. Cheap-and-sensitive first, expensive-and-specific second — the same logic as airport security and medical screening.

6 Insider Threat: Behaviour Baselines

With 15 compromised accounts among 500,000 logs, per-event rules drown in false alarms. **User behaviour analytics** instead models each user's own normal pattern — e.g. login hour mean 9.4 h, s.d. 1.8 h — so that a 02:17 Saturday login is about four standard deviations from that user's baseline. An LSTM autoencoder over 50-event sequences, trained on 475 clean users, with a per-user threshold of mean +3 s.d. of rolling reconstruction error ($0.031 + 3 \times 0.014 = 0.073$), detected 13 of 15 compromised accounts within 48 hours, with 3 false alarms in 30 days. Mean time to detection was 31.4 hours against an industry average of about 207 days. The two misses were analysts whose legitimate weekend work was already part of their baseline, and whose stolen credentials were used in normal hours — adding features on unusual combinations of data categories would help.

7 Graph-Based Detection

After an initial compromise attackers move laterally toward high-value systems. Representing connections as a graph $G_t = (V, E_t)$ and comparing it with a 90-day baseline exposes **first-ever edges** (e.g. a workstation contacting the domain controller), which were only 1.4% of connections. A graph autoencoder (graph convolution encoder, inner-product decoder $\tilde{A} = \sigma(hh^\top)$) flags nodes whose connections it reconstructs badly. On 25 simulated command-and-control channels in a 10,000-node network it detected 22 within 6 hours with 4.2 false positives per 10,000 nodes per day; the 3 misses used domain-generation algorithms, suggesting a DNS-entropy feature.

8 Comparison

Method	TPR	FPR	AUROC	Train	Infer	Explainable
z-score/IQR	58–62%	2.4–2.8%	0.83	0.1 s	<0.01 ms	yes
Mahalanobis	72.1%	1.8%	0.912	2.4 s	0.03 ms	yes
Isolation Forest	91.4%	1.1%	0.976	0.4 s	0.002 ms	partly
One-class SVM	89.7%	0.9%	0.971	38 s	4.2 ms	limited
Autoencoder	**95.8%**	**0.6%**	**0.988**	12.8 s	0.04 ms	limited

These are benchmark-style results; real enterprise networks produce many more false alarms from legitimate unusual activity (backups, patching), so thresholds must be re-tuned operationally. Even 0.6% FPR on a million packets a day is 6,000 alerts — hence the tiered design.

9 Deeper Dive I: Evaluating Detectors Properly

9.1 Choosing the operating point

An anomaly detector outputs a score; the threshold sets the trade-off between detection and false alarms. Plotting TPR against FPR over all thresholds gives the ROC curve; but at extreme imbalance the useful quantity is **alerts per day** and **precision**. With n_N normal and n_A anomalous events per day,

$$\text{false alerts} = \text{FPR} \cdot n_N, \qquad \text{precision} = \frac{\text{TPR} \cdot n_A}{\text{TPR} \cdot n_A + \text{FPR} \cdot n_N}.$$

Analyst capacity sets a ceiling on total alerts, so in practice one fixes the alert budget and maximises detections within it.

Worked example — alert budget

A security operations centre can triage 200 alerts per day on a network of 2 million events with 50 true intrusions. To keep false alerts near 150, the detector needs FPR $\leq 150/2{,}000{,}000 = 0.0075\%$ — eighty times stricter than the 0.6% achieved on the benchmark. Tiering, aggregation (alert per host rather than per packet) and enrichment with threat intelligence are how real systems close this gap.

9.2 Partial AUC and precision at k

Because only the low-FPR end of the ROC curve is usable, compare detectors by the **partial AUC** over FPR $\in [0, 0.01]$, or by **precision at** k: of the top k scored events (e.g. the 100 an analyst will see), how many are real?

10 Deeper Dive VI: Building an ROC Curve from Scores

Worked example — ten scored events

A detector scores ten events (A = attack, N = normal), sorted from highest: 0.95 A, 0.90 A, 0.80 N, 0.70 A, 0.60 N, 0.50 N, 0.40 A, 0.30 N, 0.20 N, 0.10 N (4 attacks, 6 normal). Lowering the threshold one event at a time gives (FPR, TPR) points: (0, 0.25), (0, 0.5), (0.17, 0.5), (0.17, 0.75), (0.33, 0.75), (0.5, 0.75), (0.5, 1.0), then (0.67, 1), (0.83, 1), (1, 1). The AUC is the fraction of (attack, normal) pairs ranked correctly: attacks at 0.95 and 0.90 beat all 6 normals (12 pairs), the attack at 0.70 beats 5, the attack at 0.40 beats 3: AUC $= 20/24 = 0.83$. Precision among the top 3 alerts is 2/3.

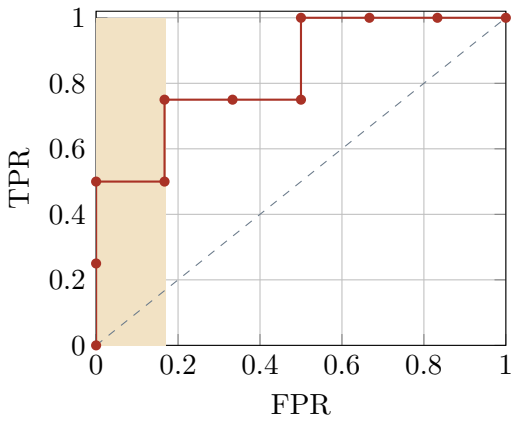


Figure 3: step ROC curve for the ten events (AUC 0.83). The shaded band is the low-FPR region that matters operationally.

11 Deeper Dive II: Statistical Detectors in Detail

11.1 Robust location and scale

The mean and standard deviation are themselves distorted by outliers. Robust alternatives: the **median** and the **median absolute deviation** MAD $=$ median$|x_i -$ median$(x)|$; the modified z-score $0.6745(x -$ median$)/$MAD flags $|z| > 3.5$.

Worked example — one outlier breaks the z-score

Login counts per hour: 10, 12, 11, 13, 9, 11, 100. Mean 23.7, sample s.d. 33.7: the value 100 has $z = 2.3$ and is *not* flagged at $z > 3$ — the outlier inflated σ and masked itself. Median 11, MAD $= 1$ (deviations 1, 1, 0, 2, 2, 0, 89): modified $z = 0.6745 \times 89/1 = 60$, flagged decisively.

11.2 From Mahalanobis distance to a threshold

If normal data are multivariate Gaussian in d dimensions, $D_M^2 \sim \chi_d^2$. For $d = 2$ the 99% point is 9.21; for $d = 41$ the 99.9% point is about 74.7 on D_M^2, i.e. $D_M \approx 8.6$. Heavy-tailed real traffic violates the Gaussian assumption, so thresholds should be checked empirically on held-out normal data.

12 Deeper Dive III: Isolation Forest Mechanics

Worked example — isolating a point by hand

Seven values on one feature: 2, 3, 3, 4, 4, 5, 20. Random splits drawn uniformly in [2, 20] usually fall above 5 (probability $15/18 = 0.83$), immediately isolating 20 in one step. To isolate the value 4 requires several splits within the narrow interval [2, 5]. Averaged over trees, $E[h(20)] \approx 1.2$ and $E[h(4)] \approx 3$–4, so 20 receives the higher anomaly score. The same logic in 41 dimensions isolates DoS packets whose byte count or connection rate is extreme.

Contamination parameter. Implementations convert scores to labels using an assumed outlier fraction; setting it to the true attack rate is circular in practice. Prefer to rank by score and set the threshold from the alert budget. **Limitations:** axis-parallel splits struggle with anomalies defined by correlations (an "extended Isolation Forest" uses random oblique splits), and features irrelevant to anomalies dilute the signal.

13 Deeper Dive IV: Autoencoder Design

13.1 Architecture choices

The bottleneck must be narrow enough that the network cannot simply copy its input (otherwise attacks are reconstructed too), yet wide enough to represent the variety of normal traffic. Typical design: symmetric layers, ReLU activations, a linear output for standardised inputs, mean-squared-error loss, early stopping on a normal-only validation set. Denoising autoencoders (trained to reconstruct clean inputs from corrupted ones) learn more robust features.

13.2 Per-feature errors for explanation

The total error $\text{RE} = \sum_j (x_j - \hat{x}_j)^2$ decomposes over features. Reporting the largest contributors ("source bytes and connection count were reconstructed worst") gives analysts an explanation and speeds triage.

Worked example — interpreting an alert

An alert has RE = 0.41; per-feature contributions: connection count 0.22, SYN-error rate 0.12, source bytes 0.05, others 0.02. The pattern (many connections, many failed handshakes, tiny payloads) is the signature of a SYN-flood denial-of-service, which the analyst can confirm in seconds.

13.3 Concept drift

Normal traffic changes: new software, new users, patch cycles. A model trained on last quarter's normal will raise more false alarms over time. Monitor the reconstruction-error distribution of normal-labelled traffic, retrain on a rolling window, and keep humans in the loop to stop attackers from slowly "teaching" the baseline to accept their behaviour (poisoning).

14 Deeper Dive V: Adversaries Who Know the Detector

Anomaly detectors face intelligent opponents. **Mimicry attacks** shape malicious traffic to resemble normal patterns (low-and-slow exfiltration below volume thresholds; command-and-control over common cloud services). **Baseline poisoning** introduces malicious behaviour gradually so it becomes "normal". Countermeasures: ensembles of diverse detectors (statistical, Isolation Forest, autoencoder, graph) so evasion must defeat all of them; features that are costly for the attacker to fake (protocol semantics, timing regularity); deception technology (honeypots, canary credentials) that produce near-zero false positives; and periodic red-team exercises.

Part C — Further Theory, Methods and Applications

15 Anomalies as Low-Probability Events

15.1 The density view

Nearly every detector in this lecture is, explicitly or implicitly, an estimate of how probable an observation is under "normal" behaviour. If $p(x)$ is the density of normal data, the natural detector flags x when $p(x) < \tau$. Gaussian models estimate p with a formula; Gaussian mixtures with several bumps; kernel density estimation with a bump at every training point; autoencoders and Isolation Forests with proxies (reconstruction error, path length). Seeing them as density estimates explains their shared weakness: density is hard to estimate in high dimensions (the curse of dimensionality, Lecture 4), so all detectors degrade as the number of features grows unless the data have low-dimensional structure.

15.2 From Mahalanobis distance to a principled threshold

If normal data are multivariate Gaussian with p features, the squared Mahalanobis distance $d^2 = (x-\mu)^\top \Sigma^{-1}(x-\mu)$ follows a χ^2 distribution with p degrees of freedom. Thresholds therefore follow from a chosen false-alarm rate rather than from guesswork.

Worked example — setting a Mahalanobis threshold

With two features, χ^2_2 quantiles are 5.99 (95%), 9.21 (99%) and 13.82 (99.9%). A false-alarm budget of one in a thousand normal events means alarming when $d^2 > 13.82$. With five features the 99.9% threshold rises to 20.52: more features, larger distances even for normal data. In practice the Gaussian assumption is only approximate, so the threshold is then checked against the empirical false-alarm rate on held-out normal data.

15.3 Extreme value theory

Thresholds for very low false-alarm rates lie in the far tail, where there are few data. **Extreme value theory** says that, for a wide range of distributions, exceedances over a high threshold follow a generalised Pareto distribution. Fitting it to the largest scores (*peaks over threshold*) lets a threshold for a 10^{-5} false-alarm rate be extrapolated from far fewer than 10^5 normal observations — with the honest caveat that extrapolation is involved.

16 Local Outlier Factor and Neighbour-Based Scores

Global methods fail when normal data have regions of very different density: a point at moderate distance from a sparse cluster is normal, while the same distance from a dense cluster is suspicious. The **local outlier factor** (LOF) compares a point's local density with that of its neighbours. With k neighbours, the reachability distance from p to o is $\max\{k\text{-distance}(o),\, d(p,o)\}$; the local reachability density of p is the inverse of its mean reachability distance to its neighbours; and

$$\mathrm{LOF}(p) = \frac{\text{mean local density of } p\text{'s neighbours}}{\text{local density of } p}.$$

LOF near 1 means the point is as dense as its neighbourhood; well above 1 means it is in a sparser region than its neighbours — a local outlier.

Worked example — LOF on eleven contacts

Two tight groups of four or five contacts (around $(0.5, 0.5)$ and $(5.5, 5.5)$), one contact at $(3, 3)$ between them and one at $(10, 0)$ far away. With $k = 3$: group members score 0.97–1.11; the in-between contact scores 2.88; the far contact 7.35. Both are flagged, and the scores rank the far contact as more anomalous — while a single global distance threshold tuned to the groups would also have to decide how to treat points between them.

Simpler neighbour scores — the distance to the k-th nearest neighbour, or the mean distance to the k nearest — often work nearly as well and are easier to explain.

17 Isolation Forest: the Score Function

For a sub-sample of size ψ, the average path length of an unsuccessful search in a binary search tree is

$$c(\psi) = 2H(\psi - 1) - \frac{2(\psi - 1)}{\psi}, \qquad H(i) \approx \ln i + 0.5772.$$

For $\psi = 256$, $c = 10.24$. The anomaly score is $s(x) = 2^{-E[h(x)]/c(\psi)}$, where $E[h(x)]$ is the mean path length of x over the trees.

mean path length $E[h]$	score s	interpretation
3	0.82	isolated almost immediately: strong anomaly
4	0.76	anomaly
6	0.67	suspicious
9.2	0.54	ordinary
$c(\psi) = 10.24$	0.50	exactly average

Scores near 1 indicate anomalies; scores well below 0.5 indicate points deep inside dense regions; if almost all scores are near 0.5 the data contain no clear anomalies. Because the trees are built on random splits, the scores of a few hundred trees are stable, and the method scales linearly with data size.

18 Boundary Methods: One-Class SVM and SVDD

The one-class SVM separates the training data from the origin in kernel feature space with maximum margin:

$$\min_{w,\xi,\rho} \ \tfrac{1}{2}\|w\|^2 + \frac{1}{\nu N}\sum_i \xi_i - \rho \quad \text{s.t. } w^\top \phi(x_i) \geq \rho - \xi_i,\ \xi_i \geq 0.$$

New points with $w^\top \phi(x) < \rho$ are anomalies. The parameter $\nu \in (0, 1]$ is an upper bound on the fraction of training points treated as outliers and a lower bound on the fraction that are support vectors. **Support vector data description** (SVDD) instead encloses the data in the smallest hypersphere in feature space; with the RBF kernel the two methods are equivalent. Both need careful choice of the kernel width: too narrow and every new point looks anomalous, too wide and the boundary becomes a loose blob.

19 Detecting Change in Sensor and Platform Data

Many defence anomalies are not single strange points but a *shift* — a bearing starting to wear, a radar's noise floor rising, a network's traffic level drifting upward. Statistical process control offers detectors designed for exactly this.

19.1 Three control charts

- **Shewhart chart:** alarm when one observation is beyond $\mu \pm 3\sigma$. Good for large sudden jumps, slow to see small shifts.
- **EWMA chart:** track $z_t = \lambda x_t + (1-\lambda) z_{t-1}$ and alarm when it leaves $\mu \pm L\sigma\sqrt{\lambda/(2-\lambda)}$. Smoothing accumulates evidence of a small persistent shift.
- **CUSUM:** accumulate deviations beyond an allowance k, $S_t = \max\{0,\ S_{t-1} + (x_t - \mu) - k\}$, and alarm when $S_t \geq h$. It is optimal for detecting a shift of a known size.

Worked example — a small drift in engine temperature

Normal operation: mean 50, standard deviation 2. Readings: 50.5, 49.2, 51.1, 49.8, 50.3, then (after a fault begins at $t = 6$, raising the mean by about 2) 52.4, 51.9, 53.0, 52.2, 52.8, 51.7, 53.1.
Shewhart (limit 56): no alarm — no single reading is extreme.
EWMA ($\lambda = 0.2$, $L = 2.5$, limit $50 + 2.5 \times 2 \times 0.333 = 51.67$): z_t climbs 50.58, 50.85, 51.28, 51.46, 51.73 and alarms at $t = 10$.
CUSUM ($k = 1$, $h = 8$): S_t runs 0, 0, 0.1, 0, 0, 1.4, 2.3, 4.3, 5.5, 7.3, 8.0 and alarms at $t = 11$.
Accumulating detectors catch a shift that point-wise thresholds never see; the price is a short delay, and both k and h (or λ and L) trade detection delay against false alarms.

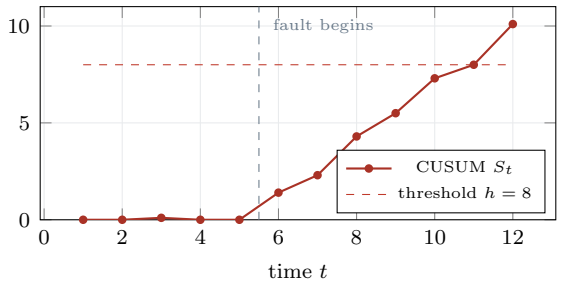


Figure C1: CUSUM accumulates a small persistent shift until it crosses the threshold.

19.2 Predictive maintenance

Vibration, temperature and oil-debris sensors on engines, gearboxes and radars are monitored with exactly these tools, often on features such as spectral band energies. Detecting degradation days before failure lets maintenance be scheduled rather than forced, which directly raises platform availability. Change-point methods (Bayesian online change-point detection, PELT) extend the idea to unknown shift sizes and to several simultaneous signals.

20 Network Intrusion Detection: Domain Knowledge

20.1 What the detector sees

Packet capture is expensive; most systems analyse **flow records** (NetFlow/IPFIX): source and destination addresses and ports, protocol, start time, duration, packet and byte counts, TCP flags. Derived features — connections per minute, distinct destinations, failed-handshake ratio, bytes in versus out, time of day — are what anomaly detectors consume. Encrypted traffic hides payloads but not these metadata.

20.2 Signature and anomaly detection

Signature-based systems (Snort, Suricata rules) match known attack patterns precisely, with few false alarms, but miss anything new. **Anomaly-based** systems find novelty but alarm on every unusual-but-benign event. Operational security centres run both: signatures for the known, anomaly detection for the unknown, with analysts in between.

20.3 The attack life cycle

Attacks unfold in stages. The **cyber kill chain** lists reconnaissance, weaponisation, delivery, exploitation, installation, command and control, and actions on objectives. The **MITRE ATT&CK** framework catalogues real adversary tactics (initial access, execution, persistence, privilege escalation, defence evasion, credential access, discovery, lateral movement, collection, command and control, exfiltration, impact) and the techniques under each. Mapping each detector to the stages and techniques it can see exposes coverage gaps: a network anomaly detector may see discovery, lateral movement and exfiltration, but not a phishing email.

20.4 The base-rate fallacy for intrusion detection

Worked example — why intrusion alarms are mostly false

A network logs 10^6 events a day, of which 20 are intrusive. A detector with 99% detection rate and a false-positive rate of 10^{-3} raises about 19.8 true alarms and 1,000 false ones: only 1.9% of alarms are real. To make half the alarms real, the false-positive rate must fall to about 10^{-5} (then 10 false alarms and a precision of 66%). Axelsson's observation (2000): in intrusion detection, the false-positive rate, not the detection rate, is the limiting factor.

21 Insider Threat and Behaviour Analytics

User and entity behaviour analytics (UEBA) builds baselines for users, hosts and service accounts and scores departures from them. Two comparisons are complementary:

- **Self-baseline:** is this unusual *for this user*?
- **Peer group:** is this unusual *for people in the same role*?

Worked example — self versus peers

A user downloads 900 MB from a document server in a day. Her own history: mean 700 MB, standard deviation 150 — $z = 1.3$, unremarkable. Her peer group of analysts: mean 120 MB, standard deviation 60 — $z = 13$, extreme. Either she has a legitimate role that differs from her

peers' (update the peer group), or her baseline itself was built while she was already exfiltrating (the contaminated-baseline problem). A purely self-referential detector would never notice a slow, long-running insider.

Insider indicators combine technical signals (unusual access times, new resources, mass downloads, removable media, privilege changes) with non-technical context held by personnel and security staff. Privacy, legal authority and proportionality govern what may be monitored; the technical capability does not settle those questions.

22 Graph Signals: Rarity and Lateral Movement

An attacker who has compromised one machine moves to others, creating connections that rarely or never occurred before. A simple and effective score is the **surprise** of an edge, $-\log_2 \hat{P}(\text{edge})$, with the probability estimated from history with smoothing.

Worked example — a first-ever connection

A workstation has made 10,000 connections in the past month, none to the domain controller. With add-one smoothing, $\hat{P} = 1/10{,}001$, surprise $= 13.3$ bits. A destination it has contacted 50 times scores $-\log_2(51/10{,}001) = 7.6$ bits. Summing surprise along a path of new connections highlights chains such as workstation → file server → domain controller — the typical route of privilege escalation. Graph autoencoders (as in the lecture's C2-detection case) learn the same notion of "unlikely structure" from data rather than counts.

23 Operating Detectors in Practice

23.1 Evaluation over time

Normal behaviour changes: new software, new exercises, deployment to a new theatre. Detectors must be evaluated on data *later* than their training data, and reported with **time to detect**, alarms per analyst-shift and the fraction of attacks detected before their objective was reached — not only AUC.

23.2 Alert triage and the feedback loop

Alerts from many detectors are correlated (same host, same time window, same user) into incidents, prioritised by asset criticality and score, and investigated by analysts. Analysts' verdicts are the most valuable labels the system will ever get: feeding them back — **active learning**, in which the system asks analysts about the cases it is least certain of — turns an unsupervised detector progressively into a supervised one.

23.3 Adversaries who learn

Attackers adapt. **Evasion** (mimicry) shapes malicious activity to resemble normal behaviour: slow exfiltration, traffic blended into business hours. **Poisoning** introduces malicious behaviour gradually during the baseline period so that it becomes "normal". Defences include training on carefully vetted periods, monitoring for slow drift in baselines, using several detectors with different blind spots, and keeping the exact features and thresholds confidential.

Key point

An anomaly detector is a sensor, not a judge. Its output is an alert with an explanation; the decision about what the anomaly means — benign, suspicious or hostile — belongs to a trained analyst.

24 Further Self-Test Questions

Check your understanding — Part C

(1) With three features, what Mahalanobis d^2 threshold gives a 1% false-alarm rate for Gaussian normal data? (2) Why can LOF flag a point that a global distance threshold would accept? (3) In the engine example, why did the Shewhart chart never alarm? (4) A detector has a false-positive rate of 10^{-4} on 10^6 daily events containing 20 intrusions, with 95% detection. Estimate its precision. (5) Why is a user's own baseline insufficient for insider-threat detection?
Answers. (1) $\chi^2_{3,0.99} = 11.34$. (2) LOF compares with local density, so a point in a sparse gap next to a dense cluster stands out even if it is not far in absolute terms. (3) The shift was about one standard deviation; no single reading exceeded $\mu + 3\sigma = 56$. (4) True alarms ≈ 19, false ≈ 100: precision $\approx 16\%$. (5) A slow or long-running insider contaminates the baseline, so abnormal behaviour becomes the user's normal; peer-group comparison catches it.

25 Implementation Notes

```
from sklearn.ensemble import IsolationForest
from sklearn.svm import OneClassSVM
from sklearn.covariance import MinCovDet
iforest = IsolationForest(n_estimators=100, max_samples=256,
random_state=0).fit(X_normal)
scores = -iforest.score_samples(X_test)   # higher = more anomalous
mcd = MinCovDet().fit(X_normal); d2 = mcd.mahalanobis(X_test)
ocsvm = OneClassSVM(kernel="rbf", nu=0.05, gamma=0.1).fit(X_normal_subsample)
tau = np.percentile(recon_error(X_val_normal), 99.4)   # 0.6% FPR budget
```

26 Self-Test Questions

Check your understanding — five questions

1. Why can a single extreme value escape a $|z| > 3$ rule? **2.** With 1,000,000 normal events per day, what FPR keeps false alerts below 100? **3.** Why is a too-wide autoencoder bottleneck a problem? **4.** An alert's reconstruction error is dominated by connection count and SYN errors. What attack is suggested? **5.** How might an adversary defeat a behaviour-baseline insider detector, and how would you counter it?
Answers. 1: it inflates the standard deviation (masking); use median/MAD. 2: 10^{-4}, i.e. 0.01%. 3: the network can copy inputs, reconstructing attacks well too. 4: a SYN-flood DoS. 5: by acting slowly within the victim's normal hours and data scope, or poisoning the baseline gradually; counter with peer-group comparison, access-combination features, canary files and periodic baseline audits.

27 Across the Disciplines

Shewhart's control charts (Bell Labs, 1920s) flag out-of-control processes at $\pm 3\sigma$; aircraft engine-health monitoring tracks each engine against its own baseline; the immune system's self/non-self discrimination inspired artificial immune systems for intrusion detection (Forrest et al., 1994); Mackworth's clock test (1948), built to study RAF radar operators, showed vigilance decaying within half an hour — the reason automated tier-1 screening matters; Benford's law exposes fabricated numbers in audits.

28 Glossary

Autoencoder	Network trained to reconstruct its input through a bottleneck.
Isolation Forest	Ensemble of random trees scoring points by how quickly they are isolated.
Mahalanobis distance	Distance scaled by the inverse covariance.
MTTD	Mean time to detect a compromise.
ν **(OCSVM)**	Bound on outlier fraction and support-vector fraction.
Reconstruction error	$\|x - \hat{x}\|^2$, used as an anomaly score.
Zero-day	Attack type never seen before, without a known signature.